

CYBERSECURITY
PORTFOLIO REPORT

RDP Brute-Force → Compromise → Splunk Detection

SOC Investigation, Detection Engineering & Defensive Analysis

Prepared by: Sagar Bidari

Role focus: Junior SOC Analyst / Cybersecurity Analyst

Lab platform: Kali Linux • Windows • Splunk Enterprise • Windows Security Event Logs

Report classification: Portfolio / Educational Lab

ETHICAL SCOPE

All activity documented in this report was performed against isolated virtual machines owned and controlled by the lab operator. The weak account used to demonstrate compromise was disposable and created specifically for the exercise. No third-party systems or real user accounts were targeted.

MASTER PORTFOLIO EDITION

1. Executive Summary

This lab demonstrates an end-to-end security operations workflow: identify an exposed Remote Desktop Protocol (RDP) service, generate controlled password-guessing activity, collect Windows authentication telemetry, investigate the activity in Splunk, distinguish a blocked attack from a successful compromise, and convert the observations into reusable detections and defensive recommendations.

Area	Observed / Implemented
Attacker	Kali Linux – 192.168.100.134
Target	Windows host homelabvm – 192.168.100.135
Exposed service	RDP / TCP 3389
SIEM	Splunk Enterprise 10.4.2
Primary telemetry	Windows Security Event IDs 4625 (failed logon) and 4624 (successful logon)
Attack outcome A	Account cyber: 24 failed attempts; account lockout prevented password compromise
Attack outcome B	Disposable account labvictim: weak password guessed on the fifth attempt; subsequent successful authentication observed
Detection engineering	SPL searches, scheduled Splunk alert, and portable Sigma rule
ATT&CK coverage	T1046, T1110.001, T1078, T1021.001

1.1 Analyst Assessment

The strongest security signal in this exercise is not the presence of failed logons alone. Repeated failures are common in enterprise environments and can arise from user error, stale credentials, services, or misconfiguration. The higher-value investigative question is whether suspicious failures are followed by a successful authentication associated with the same source and target context.

KEY LESSON

Detection should progress from volume → source attribution → account context → time ordering → successful authentication → post-authentication activity. A burst of failures is an alert candidate; a validated success after hostile password guessing can represent an incident.

1.2 Skills Demonstrated

- Windows authentication log analysis and Event ID interpretation
- Splunk Search Processing Language (SPL) for triage, aggregation, thresholding and correlation
- SOC-style evidence collection, timeline reasoning and false-positive analysis
- Detection-as-code using savedsearches.conf and Sigma
- MITRE ATT&CK mapping and control recommendations
- Responsible testing in an isolated lab environment

2. Scope, Objectives & Architecture

2.1 Objectives

The exercise was designed to answer five practical SOC questions:

- Can the analyst verify that RDP is reachable and identify the target service?
- What Windows Security events are generated by repeated password guessing?
- Can Splunk attribute the failures to a source IP and targeted account?
- Can the analyst distinguish an unsuccessful campaign from one that results in valid authentication?
- Can the investigation be converted into repeatable alert logic and portable detection content?

2.2 Lab Architecture

```
Kali Linux / Attacker + Splunk      Windows Target
192.168.100.134                    homelabvm / 192.168.100.135
+-----+                          +-----+
| Nmap / Hydra / RDP client | -- TCP 3389 --> | Remote Desktop Service |
| Splunk Enterprise       | <-- logs ----- | Windows Security Log      |
| Receiver :9997          |                  | Splunk Universal Forwarder|
+-----+                          +-----+
```

2.3 Data Flow

Windows Security events from the target were forwarded to Splunk and searched using index=main and sourcetype=WinEventLog:Security. This allowed the analyst to move from raw authentication events to source/account aggregation and alert-oriented searches.

3. Controlled Attack Simulation

3.1 Reconnaissance

The first phase confirmed that the target exposed TCP port 3389, the default RDP service port.

```
sudo nmap -sV -p 3389 192.168.100.135
```

Observed result: 3389/tcp open, service identified as ms-wbt-server.

3.2 Password-Guessing Simulation

A controlled dictionary attack was generated from the Kali host against a lab account. The repository records the following command:

```
hydra -l cyber -P ~/password.txt -V -t 1 rdp://192.168.100.135
```

The test required a single Hydra thread and changes to the lab RDP authentication configuration to reach the authentication stage. This dependency is important: the lab configuration was intentionally weakened for telemetry generation and should not be interpreted as a recommended production configuration.

3.3 Two Outcomes

Scenario	Result	SOC Interpretation
Target account: cyber	24 failed attempts; no password recovered; account locked	Hostile authentication pattern observed, but evidence presented does not establish account compromise.
Disposable account: labvictim	Weak password guessed on fifth attempt; successful authentication subsequently observed	Controlled compromise scenario used to test success-after-failure detection logic.

EVIDENCE DISCIPLINE

A SOC report should distinguish what the logs directly show from what the analyst infers. Event ID 4625 proves a failed authentication. Event ID 4624 proves a successful logon event. Attribution to an RDP compromise should be strengthened with matching account, source, logon type, time ordering, and—where available—RDP-specific or endpoint telemetry.

4. Windows Authentication Telemetry

Event	Meaning	Why it matters
4625	An account failed to log on	Primary signal for password guessing; fields such as target account, source address, logon type and failure status provide context.
4624	An account was successfully logged on	Useful for determining whether authentication succeeded; must be correlated carefully to avoid treating unrelated successes as compromise.
Logon Type 3	Network logon	Observed in the failed events documented by this lab. This is a notable finding requiring protocol/context interpretation.
Logon Type 10	RemoteInteractive	Commonly associated with interactive Remote Desktop sessions and included in the project's detection scope.

4.1 Important Logon-Type Nuance

The repository states that the password-guessing attempts appeared as Logon Type 3, while the detection searches allow both Type 3 and Type 10. This should be presented as an observed lab characteristic, not as a universal rule that all RDP brute-force activity produces Type 3. A strong analyst should validate the authentication path and compare Security logs with RDP-specific event channels when proving an interactive RDP session.

5. Splunk Investigation Workflow

The investigation uses progressive searches: validate ingestion, isolate authentication events, attribute activity, detect bursts, inspect successes, and correlate failures with successful logons.

5.1 Baseline Failed Logons

```
index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4625
```

Purpose: confirm telemetry ingestion and quantify failed authentication volume. The repository reports 24 failed-logon events for the cyber campaign.

5.2 Isolate Network / RDP-Relevant Attempts

```
index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4625 (Logon_Type=3 OR
Logon_Type=10)
| table _time, Account_Name, Logon_Type, Source_Network_Address, Failure_Reason
```

Purpose: expose time, account, source, logon type and failure reason so an analyst can inspect the authentication pattern rather than relying on count alone.

5.3 Build an Attack Fingerprint

```
index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4625
| stats count AS failed_attempts, min(_time) AS first_seen, max(_time) AS last_seen
  by Account_Name, Source_Network_Address
| sort - failed_attempts
```

Purpose: identify concentrated failures against an account from a single source and bound the activity by first/last seen.

5.4 Burst Detection

```
index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4625
| bucket _time span=1m
| stats count AS attempts_per_min by _time, Source_Network_Address
| where attempts_per_min >= 5
```

Purpose: convert raw failures into threshold-based alert logic. The five-attempts-per-minute threshold is a lab starting point, not a universal production threshold. Production values should be baselined and tuned to the environment.

5.5 Successful Authentication from the Lab Source

```
index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4624
Source_Network_Address=192.168.100.134
```

Purpose: inspect successful logons associated with the source used in the controlled attack.

6. Compromise Correlation

6.1 Repository Correlation

```
index=main host=homelabvm sourcetype="WinEventLog:Security" (EventCode=4625 OR EventCode=4624)
| stats count(eval(EventCode=4625)) AS failures,
          count(eval(EventCode=4624)) AS successes,
          values(Account_Name) AS accounts
          by Source_Network_Address
| where failures >= 5 AND successes >= 1
```

This is a useful teaching correlation because it identifies a source that produced both repeated failures and at least one success. However, it does not by itself prove that the success occurred after the failures or that the same account was involved. A recruiter-ready report should state this limitation explicitly.

6.2 Recommended Stronger Correlation

For a production-minded extension, preserve source, account and time ordering. Field names vary by Splunk add-on and extraction, so the following should be adapted to the local schema:

```
index=main host=homelabvm sourcetype="WinEventLog:Security" (EventCode=4625 OR EventCode=4624)
| stats count(eval(EventCode=4625)) AS failures
          count(eval(EventCode=4624)) AS successes
          min(eval(if(EventCode=4625,_time,null()))) AS first_failure
          max(eval(if(EventCode=4625,_time,null()))) AS last_failure
          min(eval(if(EventCode=4624,_time,null()))) AS first_success
          by Source_Network_Address, Account_Name
| where failures >= 5 AND successes >= 1 AND first_success >= first_failure
| convert ctime(first_failure) ctime(last_failure) ctime(first_success)
```

WHY THIS IS STRONGER

The improved search groups by both source and account and adds time context. For strict sequence validation, further constrain the time window and validate that the successful event represents the expected authentication path. Then pivot into post-authentication process, network and RDP-session telemetry.

6.3 Suggested SOC Timeline Fields

Field	Analyst use
Source IP	Identify and pivot on the suspected origin
Target host	Confirm affected asset
Target account	Determine which identity was attacked
Failure count	Measure attack volume
First / last failure	Bound the password-guessing window
First success	Determine whether authentication succeeded after the suspicious activity
Logon type / process / auth package	Validate authentication context
Post-login activity	Assess impact and whether additional response is required

7. Detection Engineering

7.1 Splunk Scheduled Alert

The repository includes savedsearches.conf content for a recurring Splunk alert that detects a threshold of failed logons from a source. This demonstrates that the project moves beyond ad-hoc searching into operational detection content.

7.2 Sigma Rule

A portable Sigma rule is included for Windows Security Event ID 4625 with Logon Types 3 or 10 and a one-minute aggregation threshold. The rule is marked experimental and documents expected false positives such as stale service credentials and misconfigured applications.

PORTFOLIO VALUE

Including both SIEM-native SPL and vendor-neutral Sigma shows an understanding that detection logic should be documented, version controlled and portable—not trapped in screenshots.

8. MITRE ATT&CK Mapping

Tactic / Context	Technique	ID	Evidence in this lab
Discovery / reconnaissance	Network Service Discovery	T1046	Nmap used to confirm TCP 3389 and the exposed service.
Credential Access	Brute Force: Password Guessing	T1110.001	Dictionary password guesses generated against lab accounts.
Initial Access / account abuse context	Valid Accounts	T1078	Disposable weak account was used to demonstrate authentication with a recovered credential.
Remote Services	Remote Services: RDP	T1021.001	RDP was the remote service under test.

ATT&CK mappings describe behaviors represented by the controlled scenario; they do not replace evidence. An analyst should map only techniques supported by the observed activity and clearly separate simulated attacker actions from inferred impact.

9. False Positives, Tuning & Detection Quality

Potential benign cause	Tuning / validation approach
User mistypes password repeatedly	Compare failure rate, duration, source reputation/context, target count and eventual success.
Service or scheduled task with stale credentials	Identify service accounts; inspect regular periodic cadence; maintain controlled allowlists only when justified.
Misconfigured application retry loop	Look for machine-like regularity, stable source/target pair and operational change history.
Administrative RDP activity	Validate approved source ranges, jump hosts, VPN/RD Gateway context and change records.
Password spray	Detect one/few passwords or low-rate failures across many accounts; do not rely only on per-account thresholds.

9.1 Tuning Principles

- Baseline normal authentication failures before selecting production thresholds.
- Prefer contextual suppression over broad exclusions; an allowlisted source can still become compromised.
- Increase severity when repeated failures are followed by a validated success.
- Consider distinct-account count, target-host count and time window to identify spraying or distributed attacks.
- Retain raw event pivots so analysts can explain why an alert fired.

10. SOC Triage & Response Playbook

Stage	Analyst action
1. Validate	Confirm event source, timestamps, target host/account, logon type and source address.
2. Scope	Search for the source across other hosts/accounts; search the account across other sources.
3. Determine outcome	Identify successful authentication after the failure burst and validate the authentication/session context.
4. Assess impact	Review post-login processes, PowerShell, service creation,

	persistence, outbound connections and lateral movement telemetry.
5. Contain	If malicious activity is validated, follow organizational procedures for account reset/disable, session termination and source blocking/isolation.
6. Recover	Restore secure RDP controls, rotate exposed credentials, review lockout/MFA and remove temporary lab-style weakening.
7. Improve	Tune detections, document lessons learned and preserve evidence for future investigations.

11. Defensive Recommendations

The lab demonstrates why exposed remote access and weak credentials create unnecessary risk. Recommended controls include:

- Avoid direct Internet exposure of RDP. Use an approved VPN, Remote Desktop Gateway, zero-trust access path, or equivalent controlled remote-access architecture.
- Enable Network Level Authentication (NLA) where compatible and do not weaken it outside controlled testing.
- Require strong, unique credentials and phishing-resistant or appropriately strong MFA for remote access where supported.
- Implement sensible account lockout / smart lockout controls while considering denial-of-service trade-offs.
- Restrict inbound RDP at firewalls to approved sources and management paths.
- Centralize Windows Security telemetry and retain enough history for correlation and investigation.
- Alert on failure bursts, password-spray patterns, unusual successful remote logons and success-after-failure sequences.
- Correlate authentication with endpoint and network telemetry to determine what happened after login.

12. Findings & Lessons Learned

Finding	Security lesson
Repeated 4625 events were visible and attributable to a source	Authentication telemetry can provide a strong early warning signal.
Account lockout stopped one campaign	Preventive controls can materially change attack outcome, but detections remain necessary.
A deliberately weak account was guessed quickly	Weak passwords convert noisy attempts into valid-account risk.
4624 successes were searchable from the lab source	Successful authentication must be investigated in context, not assumed benign or malicious in isolation.
Basic correlation can overstate causality	Source-only aggregation is useful for triage but should be improved with account and time ordering.
Logon Type 3 appeared in the lab attack telemetry	Protocol and authentication-path nuances matter; analysts should validate rather than memorize one event pattern.

13. Limitations

- This is a small isolated lab, not a production enterprise environment; event volume and benign background noise are limited.
- The current repository correlation aggregates by source IP and does not strictly prove event sequence or same-account causality.
- The lab intentionally changed RDP authentication conditions to generate test telemetry; production systems should retain secure controls.
- The report focuses on authentication evidence. A mature incident investigation should also include RDP operational logs, endpoint process telemetry, network telemetry and post-authentication activity.
- Private RFC1918 addresses identify only lab systems and should not be interpreted as Internet threat attribution.

14. Portfolio / Interview Summary

60-SECOND PROJECT EXPLANATION

I built an isolated Windows/Kali lab to simulate RDP password guessing and then investigated the resulting Windows authentication telemetry in Splunk. I created SPL searches to identify failed logons, attribute them to a source and account, detect bursts, and investigate successful authentication. I then converted the logic into a scheduled Splunk alert and a Sigma rule, mapped the activity to MITRE ATT&CK, documented false positives and proposed stronger source+account+time correlation. The project taught me to distinguish an attack attempt from evidence of successful access and to avoid overstating what a single event proves.

14.1 Interview Questions the Candidate Should Be Ready to Answer

- What is the difference between Event IDs 4625 and 4624?
- Why did your lab show Logon Type 3, and when would you expect Logon Type 10?
- Why is five failures per minute only a starting threshold?
- How would you detect password spraying instead of single-account brute force?
- Why does the original source-only correlation not prove that a compromise occurred?
- What additional telemetry would you inspect after a successful RDP authentication?
- How would you reduce false positives without creating a blind spot?
- What controls would you restore or enforce in a real environment?

15. Evidence Checklist for GitHub

For maximum portfolio value, pair this report with clearly captioned screenshots and raw detection files:

Evidence	Recommended GitHub artifact
RDP service discovery	Nmap screenshot/output showing TCP 3389
Controlled password guessing	Sanitized terminal screenshot showing the lab command and target
Failed authentication evidence	Splunk screenshot showing 4625 events, source, account, time and logon type
Burst aggregation	Splunk results for attempts_per_min threshold
Successful authentication evidence	Splunk screenshot showing relevant 4624 event fields
Correlation	Table showing source, account, failures, success and timestamps
Detection-as-code	splunk_searches.spl, savedsearches.conf, rdp_bruteforce_sigma.yml
Architecture	Simple network diagram matching the documented lab

SCREENSHOT RULE

Every screenshot should prove one claim. Crop irrelevant UI, keep timestamps/field names readable, redact only information that should not be public, and add a one-sentence caption explaining what the evidence demonstrates.

Appendix A – Detection Reference

Repository artifacts reviewed for this master edition:

- README.md – project narrative, lab architecture, observed results and defensive recommendations
- detection/splunk_searches.spl – six progressive SPL searches
- detection/savedsearches.conf – scheduled Splunk alert content
- detection/rdp_bruteforce_sigma.yml – experimental portable Sigma rule

Appendix B – Reference Sources

Project repository: <https://github.com/sagarbid/rdp-bruteforce-splunk-detection>

MITRE ATT&CK T1110.001 – Password Guessing: <https://attack.mitre.org/techniques/T1110/001/>

MITRE ATT&CK T1078 – Valid Accounts: <https://attack.mitre.org/techniques/T1078/>

MITRE ATT&CK T1021.001 – Remote Desktop Protocol: <https://attack.mitre.org/techniques/T1021/001/>

MITRE ATT&CK T1046 – Network Service Discovery: <https://attack.mitre.org/techniques/T1046/>

Microsoft – Event 4624 documentation:

<https://learn.microsoft.com/windows/security/threat-protection/auditing/event-4624>

Microsoft – Event 4625 documentation:

<https://learn.microsoft.com/windows/security/threat-protection/auditing/event-4625>

Appendix C – Publication Note

This document is written as a portfolio-quality educational report. Before publishing, the candidate should verify all screenshots, timestamps, event fields and tool versions against the actual lab evidence. Do not add claims that cannot be supported by retained logs or screenshots. The strongest portfolio report is one the candidate can explain and defend line by line in an interview.